

Paint Trade HQ — Privacy Policy

Draft for review · Version 1.0-draft · 18 September 2026

Draft prepared for the tester program, written to the Australian Privacy Principles (APPs) in the *Privacy Act 1988 (Cth)*. Have a lawyer review it before the public launch. Square-bracket items must be filled in before publishing. Even if the business is under the \$3 million small-business threshold, publishing and following this policy is expected by testers and by the app stores.

This policy explains what personal information **[Legal entity name] (ABN [ABN])** trading as Paint Trade HQ ("we", "us") collects through the Paint Trade HQ web app, employee app and client links (the "Service"), why, who we share it with, and your rights.

1. Two kinds of people, two roles

- **Account holders** (painting business owners, their office team and crew). We collect your information directly to run your account. For this information we are the organisation responsible under the Privacy Act.
- **People in an account holder's records** (their clients, leads, suppliers and staff). The painting business enters and controls this information; we store and process it on their instructions. If you are a client or employee of a painting business that uses Paint Trade HQ, that business is your first point of contact about your information. We help them respond, and we apply this policy to how we handle it.

2. What we collect

When a business signs up: business name, owner name, email address (used as the sign-in name), mobile number, password (stored as a one-way hash), tester access code, agreement to the terms with date and version, IP address and browser details at sign-up.

Business profile: trading name, ABN, address, phone, website, logo, signature image, bank details for invoices, Google review link, warranty and care-note wording, invoice and quote settings.

Team members and crew: name, email, phone, role, start date, pay rate, date of birth (for birthday reminders), emergency contact, licences and qualifications with expiry dates and uploaded copies, contract and induction records, training progress, timesheets, leave, strikes and recognition notes, feedback, equipment issued, profile photo.

Timeclock location. When a crew member signs in or out of a job in the employee app, the app records the time and, if the phone allows it, the GPS position and its distance from the job site.

This is used to show the owner who is on site and to flag sign-ins far from the job. Location is captured only at sign-in and sign-out, not continuously.

Clients and leads (entered by the business): name, company, phone, email, site and postal address, how they found the business, notes, tags, call and message history, quote, invoice, payment and project history, review and follow-up preferences, SMS opt-out status.

Website enquiry forms: name, email, phone, address, message, the page it came from, IP address and browser details (for spam control).

Quotes, projects and photos: measurements and prices, site photos and before/after photos including any mark-ups and notes, daily site reports, variation approvals with the approver's name, time and IP address, completion reports.

Messages: emails and SMS sent and received through the Service, including through a connected Gmail, Microsoft 365 or IMAP inbox and a connected Twilio number.

Client link activity: when a quote, invoice, variation or completion report link is opened, we record the time, IP address and browser, and whether it was accepted, declined or paid.

Payments: card payments on client links are handled by Stripe. We receive the payment result, amount, last four digits and a payment reference. We never see full card numbers. Bank-transfer payments recorded by the business are stored as the business enters them.

Connected services: access tokens for Google Drive, Google Calendar, Gmail, Microsoft 365, IMAP and Apple Calendar (iCloud app-specific password, encrypted at rest), and Twilio credentials, so the Service can act on the business's behalf.

Usage and technical data: log-in times and devices, error reports from the app (page, error text, browser), and basic usage of features. We do not use advertising trackers.

3. How we use it

- To run the Service: accounts, quotes, invoices, projects, calendars, timesheets, messaging, reports.
- To send messages the business asks us to send: quotes, invoices, reminders, follow-ups, review requests, completion reports, welcome and onboarding emails.
- To keep accounts safe: sign-in security, rate limiting, fraud and abuse prevention, error diagnosis.
- To improve the Service, using aggregated or de-identified information where possible.
- **AI features.** Some features send parts of a business's own data (for example today's jobs, recent quotes, a client's message history, or text to polish) to an AI model provider to produce a summary or draft. Only that business's data is included. The provider is contractually not permitted to use it to train models. See section 5.
- To meet legal obligations, such as tax records and responding to lawful requests.

We do not sell personal information. We do not use it for advertising.

4. Photos and shared links — please read

- **Client links.** Quotes, invoices, variations and completion reports are shared with clients through links containing a long random code. Anyone who has the link can open it without a password. Businesses should send links only to the client and ask clients not to forward them.
- **Photos.** When a business connects Google Drive, site and quote photos are stored in that business's own Drive. To display them in the app and on client links, each photo file is set to "anyone with the link can view". The link is long and random, but it does not expire, so anyone who obtains it can view the photo. Do not photograph anything you would not want a client to see, and blur or crop people who have not agreed to be photographed. When Drive is not connected, photos are stored inside the Service.
- **Calendar feed.** A business can subscribe a phone calendar to a feed link that shows jobs, client names, addresses and invoice due amounts. The link is the only protection; reset it in Settings if it is shared by mistake.
- **Staff documents** (licences, IDs, contracts) are not stored in Drive and are not shared by link. They are visible only to the business's admin users and to the staff member concerned.

5. Who we share it with

We share personal information only with providers that help us run the Service, on our instructions and under contracts or terms that restrict their use of it:

Provider	What for	Where data is processed
[Hosting provider, e.g. Emergent / cloud region]	Servers and database for the Service	[Region — confirm]
Resend	Sending email (quotes, invoices, reports, notifications)	United States
Twilio	Sending and receiving SMS, when the business connects a number	United States
Stripe	Card payments on client links; our own subscription billing later	United States, Australia
Google (Drive, Calendar, Gmail)	Photo storage, calendar overlay, inbox sync — only when the business connects them	Global
Microsoft 365	Inbox sync, when connected	Global
Apple (iCloud CalDAV)	Calendar overlay, when connected	Global
AI model provider (currently OpenAI, accessed through Emergent)	AI summaries, briefings, drafts	United States

Provider	What for	Where data is processed
A weather service and a geocoding service	Weather in the briefing; turning addresses into map positions	[Provider — confirm]

Some of these providers are outside Australia, mainly in the United States. By using the Service you consent to that overseas disclosure, and we take reasonable steps to ensure those providers handle the information in a way consistent with the Australian Privacy Principles.

We may also disclose information: to the business that entered it; when the law requires it; to our lawyers, accountants and insurers under confidentiality; and to a buyer of the business, who must honour this policy.

6. Security

Passwords are hashed. Traffic is encrypted in transit (HTTPS). Sessions expire and can be signed out from other devices. Each business's data is separated from every other business's, and this separation is tested automatically as part of our release process. Third-party credentials are encrypted at rest or held only as revocable tokens. Access to production systems is limited to the people who need it. No system is perfectly secure; if we become aware of a data breach likely to cause serious harm, we will notify affected people and the Office of the Australian Information Commissioner as the *Notifiable Data Breaches* scheme requires.

7. Cookies and local storage

The app stores your sign-in token, role and a few display preferences in your browser's local storage so you stay signed in and the app remembers your settings. We do not use third-party advertising cookies. Payment pages use Stripe's own cookies.

8. How long we keep it

- **While the account is open:** for as long as the business keeps it.
- **After an account is closed:** 30 days in live systems for recovery, then deleted; backups are overwritten within a further 60 days.
- **Tester program:** test data may be reset or wiped as part of development (see the Terms). Keep your own copies.
- **Records we must keep:** payment and tax records for as long as the law requires (generally 5 years).
- **Client link activity, error reports and security logs:** up to 12 months.

9. Your rights

- **Access and correction.** Account holders can see and edit most of their information in the app. Anyone can ask us for a copy of the personal information we hold about them, or ask us to correct it, by emailing [privacy email]. We respond within 30 days. If you are a client or employee of a painting business, we will usually direct the request to that business and help them answer it.
- **Deletion.** Ask the business, or us, to delete your information. We delete it unless we must keep it by law.
- **Opt-out of messages.** Reply STOP to any SMS, or use the unsubscribe link in marketing emails. Service messages about your own quote or invoice may still be sent by the business.
- **Withdraw consent for location.** Crew can deny location permission on their phone; sign-ins will then be recorded without a position.
- **Complaints.** Email [privacy email] and we will acknowledge within 7 days and respond within 30. If you are not satisfied, you can complain to the Office of the Australian Information Commissioner at oaic.gov.au.

10. Children

The Service is for businesses. We do not knowingly collect information from anyone under 15. Crew members aged 15 to 17 may be added by their employer, who is responsible for having their guardian's consent where required.

11. Changes to this policy

We will post any change here with a new version and date, and email account owners about changes that materially affect how we handle their information. The current version is always the one shown at the top.

12. Contact

Privacy Officer, [Legal entity name] · [address] · [privacy email] · [phone]